

AI Pen Tester v3.0

Quick-Start Guide

Five assessment types. CVSS scoring. 12 compliance frameworks.

At a Glance

The skill supports five target types. Run individual assessments first, then optionally correlate findings across connected systems.

Target Type	What you provide	Controls	Report
Website	A live URL	63 (13 families)	Interactive HTML + Markdown
Claude Skill	SKILL.md content or path	63 (13 families)	Interactive HTML + Markdown
API	API endpoint + docs/spec	53 (13 families)	Interactive HTML + Markdown
Source Code	Code files (Python, JS/TS, Rust)	51 (12 families)	Interactive HTML + Markdown
Connected Systems	2+ completed assessments	27 (9 families)	Correlation HTML + Markdown

1 — Test a Website

Use this when you have a live URL you want to assess for security vulnerabilities.

Trigger phrases

Say any of the following (or something similar) to start:

"Run a pen test on <https://example.com>"

"Test my site for vulnerabilities"

"Security audit <https://example.com>"

"OWASP assessment of my website"

Steps

1. **Provide the URL.** Paste the full address including https://.
2. **Answer scope questions.** Claude will ask about controls scope (all or subset), report format (HTML, Markdown, or both), and compliance framework.
3. **Wait for the assessment.** Claude reads the controls library, profiles the target, tests every applicable control, calculates CVSS v3.1 scores, and generates the report.

What you get

- **Interactive HTML dashboard** with severity filters, reachability toggles, CVSS score blocks, finding cards, mitigations, and export buttons.
- **Markdown report** for pasting into tickets, wikis, or email.
- Each finding includes a CVSS v3.1 score with vector string, severity rating, reachability rating, CIA classification, worst-case exploit summary, and 2–3 remediation options with code artifacts.
- **Framework filter** to view findings mapped to any of 12 compliance frameworks (OWASP, NIST, ISO 27001, PCI-DSS, SOC 2, HIPAA, CMMC, DoD SRG, FedRAMP, SEC/FINRA, EU DORA, EU AI Act).

Tip: If you only want specific control families (e.g. just Authentication and Input Validation), tell Claude during the scope step. This makes the assessment faster and the report shorter.

2 — Test a Claude Skill

Use this when you want to assess the security posture of a Claude skill (SKILL.md and its supporting files).

Trigger phrases

Say any of the following (or something similar) to start:

"Review my Claude skill security"

"Pen test this skill"

"Security assessment of my skill"

"Check compliance of my skill controls"

Steps

1. **Provide the skill.** Paste the SKILL.md content, give the file path, or point Claude to the skill directory.
2. **Answer scope questions.** Same as a website assessment — controls scope, report format, and framework.

3. **Wait for the assessment.** Claude tests the same 63 controls (including the SKILL family for prompt injection, tool permissions, and scope limits) and generates the report.

What you get

- The same interactive HTML dashboard and Markdown report as a website assessment, with CVSS scores and reachability ratings.
- SKILL-family controls check for prompt injection risks, over-permissive tool access, and missing scope boundaries.

Tip: Point Claude at the entire skill directory (not just SKILL.md) so it can examine reference files, templates, and any helper scripts for additional attack surface.

3 — Test an API

Use this when you have an API endpoint (REST, GraphQL, or similar) you want to assess for security vulnerabilities. Works best with an OpenAPI/Swagger spec or API documentation.

Trigger phrases

Say any of the following (or something similar) to start:

"Pen test my API at https://api.example.com"
"Security assessment of my REST API"
"Test this API for OWASP Top 10 issues"
"Check my GraphQL endpoint for vulnerabilities"

Steps

1. **Provide the API.** Share the base URL, an OpenAPI spec, or API documentation. Include authentication details if available.
2. **Answer scope questions.** Claude will ask about controls scope, report format, and compliance framework.
3. **Wait for the assessment.** Claude reads the API controls library (53 controls across 13 families), tests each applicable control, calculates CVSS scores, and generates the report.

What you get

- **Interactive HTML API Report** with the same filter/export UI as the website report.
- API-specific control families include BOLA (Broken Object-Level Authorization), Mass Assignment, Rate Limiting, and SSRF.
- Each finding includes CVSS v3.1 scoring, reachability rating, and remediation artifacts tailored to API patterns.

Tip: Providing an OpenAPI/Swagger spec gives Claude the full endpoint map, parameter types, and authentication schemes — leading to a more thorough assessment than a base URL alone.

4 — Review Source Code

Use this when you want a security-focused code review with complexity analysis. Supports Python, JavaScript/TypeScript, and Rust.

Trigger phrases

Say any of the following (or something similar) to start:

"Review my code for security issues"
"Code review this Python file"
"Check my JS code for vulnerabilities"
"Run a secure code review"
"Static analysis of my codebase"
"Audit my Rust code"

Steps

1. **Provide the code.** Paste source code, upload files, or point Claude to a directory.
2. **Answer scope questions.** Claude will ask about the languages to review and which domain families to include (Security, Complexity, Development Practices — or all three).
3. **Wait for the review.** Claude reads the code review controls library (51 controls across 12 families in 3 domains), analyses the code, and generates the report.

What you get

- **Interactive HTML Code Review Report** with the same filter/export UI as the website report, plus these extras:
 - **Code excerpts** showing the exact vulnerable lines with line numbers, highlighted in red.
 - **Complexity metrics** (cyclomatic, cognitive, Halstead) with threshold indicators.
 - **Footnote source marks** linking each finding to its authoritative framework (OWASP ASVS, CWE Top 25, SEI CERT, etc.).
 - **Complexity summary table** listing every function that exceeds a threshold, with a refactoring verdict.
 - **Legend section** mapping all 12 footnote marks to their source framework name, version, and coverage.

Tip: The three code review domains are colour-coded — **SEC** (Security, purple), **CPX** (Complexity, cyan), and **DEV** (Development Practices, amber). Use the domain pills to filter findings by domain.

5 — Connected Systems

Use this after completing two or more individual assessments (website, API, skill, or code review) on systems that are connected. Claude identifies multi-step attack chains that span systems and re-scores findings whose risk changes in a cross-system context.

Trigger phrases

After your individual assessments are done, say something like:

"Analyze how these systems connect"
"Check for cross-system attack chains"
"Run a connected systems assessment"
"How do vulnerabilities in my API affect my website?"

Steps

1. **Confirm the systems.** Claude will list the assessments from this session. Confirm which two (or more) are connected and describe the connection (e.g. "the website calls the API for authentication").
2. **Wait for correlation.** Claude reads the cross-system controls library (27 controls across 9 families), identifies attack chains, calculates compounded CVSS scores, and generates the report.

What you get

- **Chained Vulnerabilities** — multi-step exploit paths that span systems. Each chain shows the step-by-step flow with colour-coded system badges (blue = website, green = API, purple = skill, orange = code), a compounded CVSS score, and remediation options.
- **Compounded Risk** — individual findings from earlier assessments whose severity or reachability changes because of the cross-system connection. Shows original vs. re-scored CVSS side by side with justification.
- Collapsible section headings with live counts that update as you filter.
- **Review & Export** compiles your chosen mitigations for chains plus all re-scored findings into a single Markdown or JSON remediation bundle.

Tip: The Connected Systems report is a post-assessment step — Claude will not run it automatically. Ask for it after you have at least two completed assessments in the same session.

6 — Working with the Report

All five assessment types produce an interactive HTML report. Here is the fastest way to use it.

Triage workflow

1. **Filter to Critical.** Click the red CRITICAL pill. For code reviews, also click the SEC domain pill.
2. **Check CVSS scores.** Each finding shows a colour-coded CVSS v3.1 block with the numeric score, severity label, and full vector string. Use this to prioritize within a severity level.

3. **Read worst-case summaries.** Expand each finding card and read the red "Risk" box — it describes what happens if the issue is not fixed.
4. **Pick a mitigation.** Each finding offers 2–3 remediation options with code artifacts. Click the radio button next to your choice.
5. **Preview the fix.** Click "Preview artifact" to see the full remediation code inline.
6. **Work down severity levels.** Move to High, then Medium. Use the Status filter ("No selection") to find unaddressed findings.
7. **Export.** Click "Review & Export" to download a Markdown or JSON bundle of all your selected mitigations.

Key UI elements

Element	What it does
Severity pills	Toggle to show/hide findings by severity level (Critical, High, Medium, Low, Informational).
Reachability pills	Toggle by reachability rating: Direct, One Hop, Multi-Step, Internal.
CVSS score block	Colour-coded block showing numeric score (0.0–10.0), severity label, vector string, and progress bar.
Framework filter	Multi-select dropdown to view findings mapped to specific compliance frameworks (OWASP, NIST, ISO 27001, PCI-DSS, etc.).
Domain pills (code review)	Filter by SEC (security), CPX (complexity), or DEV (development practices).
Status filter	Filter by mitigation status: all, selected, or no selection yet.
Finding cards	Click to expand. Shows CVSS, severity, reachability, description, worst-case exploit, mitigations, and artifacts.
Section headings (connected systems)	Click "Chained Vulnerabilities" or "Compounded Risk" to collapse/expand that section. Count updates with filters.
Bulk buttons	Expand All / Collapse All / Clear Selections for quick batch operations.
Review & Export	Opens a modal to review and download your remediation bundle as Markdown, JSON, or copy to clipboard.

For the full reference (control families, severity definitions, CVSS calculation guide, source framework legend, and detailed UI walkthrough), see the **Security Assessment & Remediation Guide** (the companion PDF).